Breathing Room: Features, architecture and compliance map

Oct 12, 2026 · @Marcus

Summary

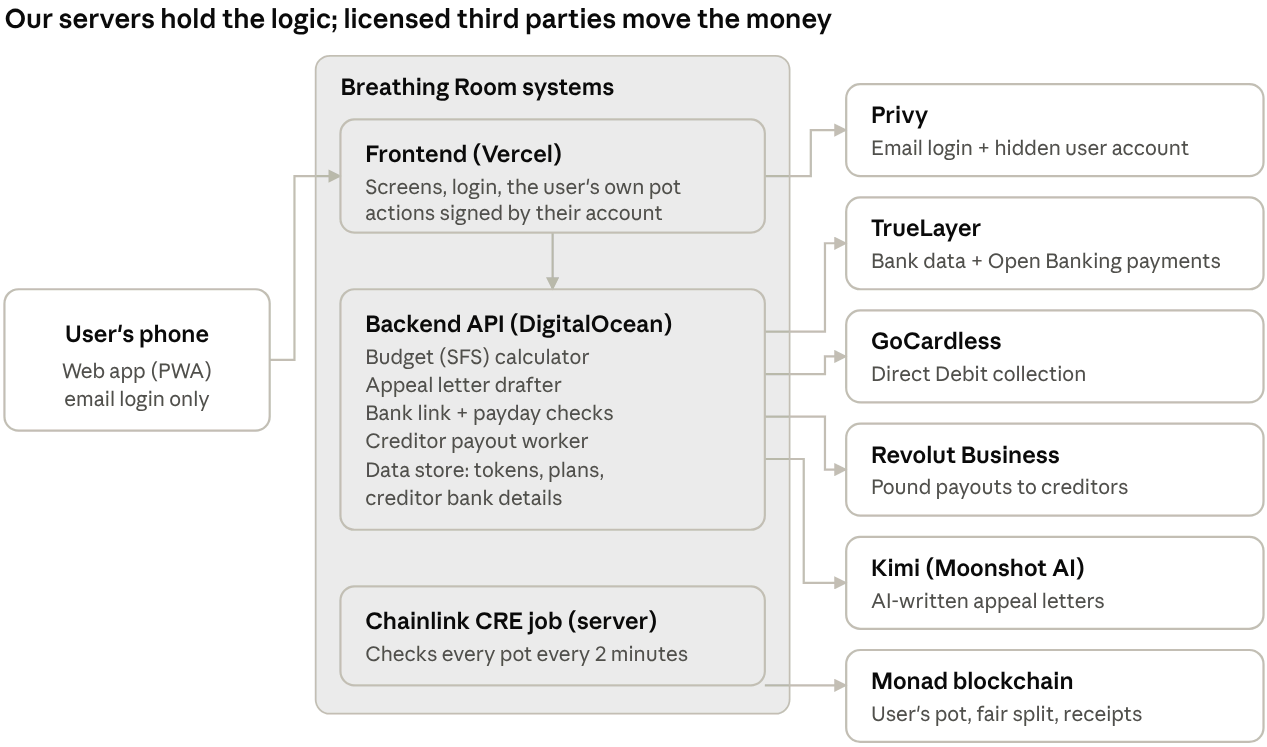
This is the source list for Breathing Room's terms, privacy policy and compliance work: every feature, every piece of personal data, every third party, and the rules each one touches. It reflects the app as built on 12 Oct (hackathon sandbox build), not a finished production service.

Three areas matter most, in order:

1. **Money movement (FCA payment services).** Collecting from users and paying their creditors is regulated. Production needs a licensed partner (Modulr is the researched option) where each user has their own safeguarded account.
2. **Debt advice (FCA debt counselling).** The app must stay an information and calculation tool, or the advice must sit under a regulated charity partner's permission.
3. **Health data (UK GDPR Article 9).** Disability, neurodivergence and caring details used in appeal letters are special category data and need separate, explicit consent, which the app already asks for.

It builds on the repo's existing docs/regulatory_guardrails.md and docs/data_protection.md, and corrects them where the build has moved on.

Architecture



All in sandbox or testnet today. Production swaps Revolut for a licensed partner (e.g. Modulr).

system architecture · our systems and 6 third parties

The user only ever talks to our frontend. Our backend holds the logic and talks to each provider; the money itself moves through the providers and the user's pot on Monad. The backend also reads payout records from Monad and, for the demo only, tops up pots with test tokens (the simulated on-ramp).

Features

Feature	What it does	Personal data it touches	Status
Email login	Privy email + one-time code; creates a hidden blockchain account for the user	Email address	Live

Feature	What it does	Personal data it touches	Status
Budget calculator (SFS)	Works out income, essentials, a £5–£25 buffer and each creditor's fair share, using the MaPS Standard Financial Statement method. No AI in the maths	Income, outgoings, creditor names and balances	Live, no login needed
Auto-fill budget from bank	Reads 3 months of transactions (read-only) and averages them	Full transaction history, account details	Live (sandbox)
Deficit budget handoff	If nothing is left after essentials, shows National Debtline, Citizens Advice and Breathing Space instead of a plan	None extra	Live
Appeal / debt letter drafting	Drafts a letter for the user to send themselves: council PCN, private parking, creditor payment-plan request. Bailiff and court letters go to an adviser	Notice details (issuer, reference, dates, amount), reasons in the user's own words	Live (template; AI once KIMI is topped up)
Health and circumstances consent gate	Separate opt-in before disability, neurodivergence, Blue Badge or caring details can be added to a letter	Special category health data (only with consent)	Live
Link bank (Open Banking)	TrueLayer read-only consent to spot payday	Bank tokens, transactions	Live (sandbox)

Feature	What it does	Personal data it touches	Status
Automatic payday collection	User approves a Direct Debit (GoCardless) or Open Banking mandate (TrueLayer) once; on payday the surplus is collected	Name, email, bank account (held by the provider), payment amounts	Live (sandbox)
The pot	A smart contract the user owns on Monad: holds the collected money briefly, then splits it fairly	Wallet address, amounts (public on the blockchain)	Live (testnet)
Automatic payout trigger	Chainlink CRE checks each pot every 2 minutes and triggers the split	None beyond the above	Live (simulator on our server)
Creditor payouts in pounds	Each creditor's share is sent by bank transfer with their reference	Creditor bank details, address and the user's reference (PCN / account no.)	Live (Revolut sandbox)
Activity feed and receipts	Shows each step; every split is a public on-chain receipt	Event history	Live
Push notifications	Notifies the user about events	Push subscription	Partly built
Letter scanning (camera / OCR)	Planned: read a letter photo into the form	Photo of the letter	Not built

Personal data we handle

Data	Special category?	Where it lives today	Gap to close
Email address	No	Privy	Privacy policy must name Privy
Income, outgoings, creditors (budget)	No, but financial and sensitive	The user's browser session; sent to our backend to calculate	Decide whether we store budgets at all
Bank transactions and account details	No, but financial	Read from TrueLayer; bank tokens kept in the backend data store	Encrypt the data store; tokens expire after 90 days and need re-consent
Notice details (issuer, reference, dates, amount)	No	Sent to the backend; sent to Kimi when AI drafting is on	Redact identifiers before AI (not built)
Disability, neurodivergence, Blue Badge, caring crisis	**Yes (Article 9)**	Only with explicit consent; sent to the backend and to Kimi when AI drafting is on	Redaction, international transfer check, withdraw-and-delete in settings (not built)
Creditor bank details, address, reference	No (about the creditor), but tied to the user's debts	Backend data store	Encrypt; retention period
Wallet address and payment amounts	Pseudonymous	Public on the Monad blockchain, permanently	Tell users clearly: on-chain records can't be deleted
Activity history	No	Backend data store (last 20 events per user)	Retention period

Two things to state plainly in the privacy policy: blockchain records are public and permanent (no names are written on-chain, but amounts and timing are), and health details are only ever used to draft the user's own letter.

Third parties

Provider	What they do for us	Data they receive	Note for the policy
Privy	Email login, hidden user account	Email, device info	Processor
Vercel	Hosts the frontend	Usage and request logs	Processor
DigitalOcean	Hosts our backend and the Chainlink job	Everything the backend stores	Processor; confirm data-centre region
TrueLayer	Bank data; Open Banking payments	Bank account data, transactions, payment details	FCA-authorised; acts under its own permissions for the bank connection
GoCardless	Direct Debit collection	Name, email, bank account, payment amounts	FCA-authorised; Direct Debit Guarantee and advance-notice rules apply
Revolut Business	Pays creditors in pounds (demo)	Creditor bank details, amounts, references	Production: replace with a licensed embedded-accounts partner
Kimi (Moonshot AI)	Drafts appeal letters	Notice details; health details only with consent	Check where it processes data; likely an international transfer needing safeguards
Monad blockchain	Holds the pot and the split	Wallet address, amounts, timing (public)	Not a processor: a public network. Data on it is permanent

Provider	What they do for us	Data they receive	Note for the policy
Chainlink CRE	Workflow tooling for the automatic trigger	Pot addresses and balances (already public)	Runs on our server today

Compliance areas

Area	Rule	What it means for us	Status
Moving users' money	FCA payment services / e-money	Collecting and paying out for users needs authorisation, or operating through a licensed partner where each user has a safeguarded account	Demo uses sandboxes; partner route researched (Modulr)
Debt advice	FCA debt counselling and debt adjusting	Stay a calculation and drafting tool; never negotiate as the user's representative. Or advise under a regulated charity partner	Signposting in place; partner not yet chosen
Legal services	Legal Services Act 2007	Drafts only: the user reviews, signs and sends as a litigant in person. Every letter ends with a not-legal-advice line	In place
Crypto	FCA cryptoasset registration and financial promotion rules	Turning pounds into tokens for users needs a registered on/off-ramp partner. Avoid crypto promotion language	On-ramp simulated in the demo

Area	Rule	What it means for us	Status
Personal data	UK GDPR + Data Protection Act 2018	Lawful basis per data type, privacy notice, data protection impact assessment (high-risk: financial + health data), ICO registration	Notice and DPIA not written; ICO not registered
Health data	UK GDPR Article 9	Explicit, separate, never pre-ticked consent; withdraw-and-delete; declining must not weaken the letter	Consent gate built; withdraw-and-delete not built
Vulnerable customers	FCA Consumer Duty and vulnerable-customer guidance	Plain language, crisis signposting, no pressure, fair outcomes	Mostly in the design (Jay's wireframes)
Direct Debit	Direct Debit Guarantee, advance notice	Notify users before each collection, especially when the amount changes	GoCardless sends notices in production
Budgets	MaPS Standard Financial Statement licence	Free SFS membership so creditors accept our budgets	Not applied for
Online services	PECR (cookies), accessibility	Cookie consent if analytics are added; accessible design for users with disabilities	No analytics yet
Brand	Name clash	"Breathing Room" is close to the statutory "Breathing Space" scheme	Legal check needed

What the documents must cover

Terms of use

- [ ] What Breathing Room is and isn't: information, calculations and draft letters, not regulated debt advice or legal advice
- [ ] The user sends their own letters and is responsible for them (litigant in person)
- [ ] How automatic collection works: the user's approval, only the surplus is taken, how to pause or cancel
- [ ] The pot: the user owns it, when it pays out, that they can withdraw, what happens if a payment fails
- [ ] Which licensed partners provide each regulated service, and that their own terms also apply
- [ ] Creditor payments: we pay what the plan says; creditors aren't obliged to accept the plan
- [ ] Signposting to free regulated advice (National Debtline, StepChange, Citizens Advice, Breathing Space)
- [ ] Liability limits, complaints process, governing law (England and Wales)

Privacy notice

- [ ] Every data type in the personal-data table, its purpose and lawful basis
- [ ] Every third party in the table, and any transfers outside the UK (check Kimi)
- [ ] Blockchain records are public and permanent
- [ ] Retention periods; how to access, correct or delete data
- [ ] ICO registration number once registered

Consents (separate, unbundled, never pre-ticked)

- [ ] Health and circumstances details for letters (Article 9), with withdraw-and-delete
- [ ] Bank connection (Open Banking, 90-day renewal)
- [ ] Direct Debit or Open Banking payment mandate
- [ ] Notifications
- [ ] Cookies or analytics, if added

Open questions for a lawyer

1. Does suggesting each creditor's pro-rata share cross from "calculation tool" into regulated debt counselling?
2. Under a partner like Modulr, are we their agent, a distributor, or just a technology provider, and what does each mean for our obligations?

3. Who is the data controller for bank data: us, TrueLayer, or both?
4. Can health data be sent to an AI provider outside the UK, and with what safeguards? Or must it be redacted or processed in the UK only?
5. Is "Breathing Room" too close to the statutory "Breathing Space" scheme to use as a brand?
6. If creditors pay us a Fair Share contribution, does that create a conflict of interest we must disclose to users?
7. What do we owe users if an automatic collection causes an overdraft or bank charge?